

SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY

COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)
Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I K Phani Sridhar Yogi 192311091 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of the student:

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

A. Explain why storing plaintext passwords is insecure.

B. Suggest a secure method for storing passwords and justify your choice.

Solution :

A. Explain why storing plaintext passwords is insecure.

Storing passwords in **plaintext** means the passwords are saved exactly as users enter them.

Why it is insecure:

- If the database is hacked, attackers can immediately read all user passwords.
- Attackers can use the stolen passwords to access user accounts.
- Many users reuse the same password on multiple websites, increasing the risk of identity theft.
- It violates security best practices and privacy standards.

Example:

Username	Plaintext Password
Alice	alice123
Bob	password@123

Anyone who accesses the database can directly see these passwords.

B. Suggest a secure method for storing passwords and justify your choice.

Secure Method: Store passwords using a **strong password hashing algorithm** such as **bcrypt**, **Argon2**, or **PBKDF2**, along with a unique **salt** for each password.

Justification:

- Hashing converts the password into a fixed-length hash that cannot easily be reversed.
- A unique salt prevents identical passwords from producing the same hash.
- Algorithms like bcrypt and Argon2 are intentionally slow, making brute-force attacks much more difficult.
- Even if the database is compromised, attackers cannot easily recover the original passwords.

Answer: Passwords should be stored using **bcrypt (or Argon2) with a unique salt** because it provides strong protection against password theft.

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

A. Explain how digital signatures can be used in this scenario.

B. Justify how this method ensures both integrity and non-repudiation.

Solution :

A. Explain how digital signatures can be used in this scenario.

A digital signature is created using the sender's private key.

Process:

1. Calculate the hash of the document.
2. Encrypt the hash using the sender's private key to create the digital signature.
3. Send the document along with the signature.
4. The receiver decrypts the signature using the sender's public key.
5. The receiver also computes the hash of the received document.
6. If both hashes match, the document is authentic and unchanged.

B. Justify how this method ensures both integrity and non-repudiation.

Integrity

- If the document is modified during transmission, the hash value changes.
- The signature verification fails, indicating that the document has been altered.

Non-Repudiation

- Only the sender possesses the private key used to generate the signature.
- Therefore, the sender cannot deny having signed the document.

Answer: Digital signatures guarantee that the document is authentic, unchanged, and signed by the legitimate sender.

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

A. Explain how replay attacks occur.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

Solution :

A. Explain how replay attacks occur.

A replay attack occurs when an attacker captures a valid transaction and retransmits it later.

Example:

- A customer sends a payment request of ₹5,000.
- An attacker intercepts the request.
- The attacker sends the same request again.
- The system processes it as another valid payment, resulting in duplicate transactions.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

Technique: Use a **Nonce (Number Used Once)** together with a **Timestamp** and a **Message Authentication Code (MAC)** or **Digital Signature**.

Justification:

- A nonce is unique for every transaction.
- A timestamp ensures that the request is recent.
- The server rejects duplicate or expired requests.
- A MAC or digital signature verifies that the message has not been modified.

Answer: Using a **nonce, timestamp, and MAC/digital signature** effectively prevents replay attacks because each transaction is unique and cannot be reused.

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

A. Identify the risks involved in this scenario.

B. Recommend a secure communication method and justify how it protects user data.

Solution :

A. Identify the risks involved in this scenario.

Using public Wi-Fi without encryption exposes users to several risks:

- Eavesdropping on sensitive information.
- Password theft.
- Man-in-the-Middle (MITM) attacks.
- Session hijacking.
- Data tampering.
- Identity theft.

B. Recommend a secure communication method and justify how it protects user data.

Recommended Method: Use **HTTPS (TLS/SSL encryption)** or a **Virtual Private Network (VPN)**.

Justification:

- TLS encrypts all data exchanged between the user and the website.
- VPN encrypts all internet traffic between the user's device and the VPN server.
- Encryption prevents attackers on the same Wi-Fi network from reading or modifying the transmitted data.
- Authentication verifies the identity of the communicating parties.

Answer: HTTPS with TLS (and optionally a VPN) protects user data by encrypting communications and preventing eavesdropping or tampering.

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

A. Explain how hashing can be used to verify data integrity.

B. Suggest an additional mechanism to enhance trust and justify your answer.

Solution :

A. Explain how hashing can be used to verify data integrity.

A cryptographic hash function (such as **SHA-256**) generates a unique hash value for a file.

Process:

1. Generate the file's hash before uploading it.
2. Store the hash securely.
3. After downloading or accessing the file, generate a new hash.
4. Compare the new hash with the original hash.
 - If both hashes match, the data has not changed.
 - If they differ, the data has been altered or corrupted.

B. Suggest an additional mechanism to enhance trust and justify your answer.

Additional Mechanism: Use a **Digital Signature**.

Justification:

- A digital signature verifies both the integrity and the authenticity of the data.
- It confirms that the data was created by the legitimate owner.
- Any modification to the data causes signature verification to fail.
- It also provides non-repudiation.

Answer: Combining **SHA-256 hashing** with **digital signatures** provides strong assurance that the cloud data remains authentic, unaltered, and trustworthy.